



OrbitalFire DEMO Assessment

TECHNICAL REPORT

OrbitalFire

January 29, 2026

Copyright

© OrbitalFire. All Rights Reserved. This is unpublished material and contains trade secrets and other confidential information and is subject to a confidentiality agreement. The unauthorized possession, use, reproduction, distribution, display, or disclosure of this material or the information contained herein is prohibited.

The methodology used to audit the computer systems is considered proprietary intellectual information of OrbitalFire and may not be disclosed without written permission from OrbitalFire. OrbitalFire gives permission to copy this report for the purpose of disseminating information within your organization, or any regulatory agency.

Confidentiality

This document contains organization confidential information of a proprietary and sensitive nature. As such, this document should be afforded the security and handling precautions that a confidential document warrants. This document should have a controlled distribution to relevant parties only and should not be copied without written permission. OrbitalFire treats the contents of a security audit as organization confidential material and will not disclose the contents of this document to anyone without written permission.

Assessment Project Team

Below is a list of contacts that were involved in this engagement. Should you have any questions pertaining to the content of this document or any project and non-project-related items, please feel free to reach out to the necessary project contacts.

Primary Point of Contact	
Name:	Reg Harnish
Title:	Reg
Office:	+1(518) 229-1157
Email:	reg@orbitalfire.com

Threat Severity Rankings

To assist the organization with prioritizing findings, the findings and observations have been categorized with threat severity rankings based on the following guidelines:

SEVERITY		DESCRIPTION
	Critical	A critical threat ranking requires immediate remediation or mitigation. Exploiting these vulnerabilities require a minimal amount of effort by the adversary but poses a significant threat to the confidentiality, integrity, and/or availability of the organization's systems and data. A successful compromise of findings of this ranking leads to access to multiple systems and/or several pieces of sensitive information.
	High	A high threat ranking requires immediate remediation or mitigation. Exploiting these vulnerabilities require a minimal amount of effort by the adversary but poses a significant threat to the confidentiality, integrity, or availability of the organization's systems or data. A successful compromise of findings of this ranking leads to access to a single system or limited sensitive information.
	Medium	A medium threat ranking requires remediation or mitigation within a short and reasonable amount of time. These findings typically lead to a compromise of non-privileged user accounts on systems and/or applications or denote a denial-of-service (DoS) condition of the host, service, or application.
	Low	A low threat ranking requires remediation or mitigation once all higher prioritized findings have been remediated. These findings typically leak information to unauthorized or anonymous users and may lead to more significant attacks when combined with other attack vectors.
	Informational	An informational threat ranking does not pose a significant threat to the environment and may just be findings that could potentially disclose valuable information but do not expose the organization to any technical attacks. Findings rated as informational may be useful for an attacker performing information gathering on the organization to leverage in other attacks, such as social engineering or phishing.

Discovered Threats

DISCOVERED THREATS		THREAT SEVERITY RANKINGS
External Network Penetration Test (3)		
Subdomain Takeover Vulnerability		High
Misconfigured DMARC Record		Medium
Remote SSH Service Exposed to Public Internet		Medium

MITRE ATT&CK Mappings

This section of the report contains details about the tactics, techniques, and procedures as defined by the MITRE ATT&CK Framework. For additional details relating to these tactics, techniques, and procedures (TTPs), OrbitalFire recommends that OrbitalFire visit the specific URLs provided within the table below. Furthermore, OrbitalFire has also elaborated on how these TTPs were used during the penetration test in this report's Penetration Test Narrative section.

OrbitalFire recommends OrbitalFire thoroughly leverage this report section to investigate and improve network security policies, procedures, and controls within the organization's environment. All of the attacks mentioned in this report section should have been detected and properly logged for investigation purposes by the organization.

MITRE ATT&CK®			
Time	Name	Tactic	TTPID
Thu, Jan 29, 2026 @ 02:00:53 PM EST	Active Scanning: Scanning IP Blocks	Reconnaissance	T1595.001
Thu, Jan 29, 2026 @ 02:00:53 PM EST	Network Service Discovery	Discovery	T1046
Thu, Jan 29, 2026 @ 02:10:07 PM EST	Brute Force: Password Guessing	Credential-access	T1110.001

Reputational Threat Findings

This section addresses information that was discovered when performing information gathering about the organization. This information includes data that could be leveraged by an adversary to perform an attack, including social engineering attacks. Findings in this area focus on identifying vulnerabilities that could be used to affect the reputation, brand image, or users of the organization's various external presences.

The threat severity ranking of each finding is based on the recommended priority and order of importance as outlined in this section.

Tasks Performed

To fully assess the organization for reputational threats, OrbitalFire performed the following tasks as part of this phase of testing:

TASK PERFORMED	DOMAIN(S) ASSESSED
Performed Information Gathering: Whois, NSLookup, and ARIN Queries	www.orbitalfire.com
Performed DNS Enumeration for Hostnames	www.orbitalfire.com
Performed Username and Email Address Harvesting	www.orbitalfire.com
Performed Doppelganger Domain Searches	www.orbitalfire.com
Performed Derogatory Domain Searches	www.orbitalfire.com



Observation

One of the first things that an attacker does to gather information about an organization is perform lookups of their domain names, identify subdomains, mail servers, etc. The objective of this process is to gather as much information about the target domain so that an attacker could begin to map out the external environment of the organization. Such information could then later be used in an attack, such as social engineering. It should be noted that both the www and non-www versions of root domains (e.g. example.com) were queried against DNS servers for information.

OrbitalFire also reviewed DNS records to determine if any email spam controls are in place. This is accomplished by the use of DMARC and SPF records. Once implemented, email servers that receive emails from your domain will double check your domain's DNS records to determine if the originating email is from an authorized source. If not, the email may be completely dropped or moved to the spam folder.



Recommendation

No recommendation is necessary for this particular finding. This finding is solely information that was gathered by the consultant as part of this penetration test engagement.



Evidence

The following table displays a list of domains that were discovered using public resources:

SUB DOMAIN	IP ADDRESS
ftp.orbitalfire.com	107.180.245.182
mysql.orbitalfire.com	107.180.245.182
cyberblast-test.orbitalfire.com	52.184.193.103
cyberblastapi-test.orbitalfire.com	52.184.193.103
cyberblast.orbitalfire.com	52.184.193.103
learnmore.orbitalfire.com	199.60.103.29
cyberblastapi.orbitalfire.com	

Furthermore, the consultant reviewed the DNS records provided by the domains and subdomains discovered to attempt identifying if any valuable information could be obtained. No sensitive information has been discovered from this information.

SUB DOMAIN	RECORD TYPE	DATA
www.orbitalfire.com	SOA	ns1.dreamhost.com
www.orbitalfire.com	NS	ns1.dreamhost.com
www.orbitalfire.com	NS	ns3.dreamhost.com

www.orbitalfire.com	NS	ns2.dreamhost.com
www.orbitalfire.com	MX	orbitalfire-com.mail.protection.outlook.com
www.orbitalfire.com	A	107.180.245.182
www.orbitalfire.com	TXT	ca3-c653adaad499482dab83e77a017bb616
www.orbitalfire.com	TXT	v=spf1 include:spf.protection.outlook.com include:24080688.spf08.hubspotemail.net include:autotask.net ~all
www.orbitalfire.com	TXT	v=DMARC1; p=none;
www.orbitalfire.com	A	107.180.245.182

Informational

Doppelganger Domains



Observation

A Doppelganger domain is a domain that has been registered by an adversary that takes advantage of common typing mistakes or browser assumptions that target a legitimate domain. As an example, a common doppelganger domain for "www.abc.com" would be to register "wwwabc.com" or even "www.abccom.com".

Doppelganger domains have a potent impact when leveraged via email or bogus websites, as adversaries could potentially gather information such as trade secrets, usernames and passwords, and other employee information during social engineering attacks. Additionally, doppelganger domains have been commonly used to spread malware to users who accidentally misspell a legitimate domain in their web browser.

During testing against targeted domains, nine (9) doppelganger domains were discovered to be registered. OrbitalFire's network staff should review these results and determine the legitimacy of these domains.



Recommendation

By leveraging tools such as [URLCrazy](#), your organization may perform its own periodic review of its domains to determine if anyone has attempted to register a doppelganger domain. If a doppelganger domain is discovered, gather the registrar information, and lodge a complaint with the registrar to have the doppelganger domain removed or registered to your organization.

Additionally, it is recommended that your organization register the most common variations of its domain names and spellings as a preemptive measure to combat this form of attack.

Furthermore, the organization may consider implementing a blacklist in its mail server configuration to ensure that these doppelganger domains are not used to send phishing emails to the organization.



Evidence

MISSPELLING TECHNIQUE	DOMAIN NAME	IP ADDRESS ASSOCIATED WITH DOMAIN	COUNTRY
*original	www.orbitalfire.com	107.180.245.182	United States
subdomain	www.orbitalfi.re.com	N/A	N/A
subdomain	www.orb.italfire.com	13.223.25.84	United States
subdomain	www.orbita.lfire.com	13.223.25.84	United States
tld-swap	www.orbitalfire.online	173.236.242.26	United States
tld-swap	www.orbitalfire.blog	173.236.246.106	United States
tld-swap	www.orbitalfire.org	173.236.246.229	United States
tld-swap	www.orbitalfire.io	173.236.254.40	United States
tld-swap	www.orbitalfire.us	67.205.25.107	United States
tld-swap	www.orbitalfire.co	67.205.6.103	United States

OrbitalFire DEMO Assessment

Engagement Scope of Work

Through discussions with OrbitalFire's staff, the following target applications, IP addresses, and/or ranges were included as part of the engagement scope.

IP ADDRESSES & RANGES			
107.180.245.182 (www.orbitalfire.com)			

Agent Information

To perform this assessment, OrbitalFire used an agent consisting of the necessary tools to conduct discovery, enumeration, attacks, etc. The agent used in this assessment contained the following information:

DESCRIPTION	DETAILS
Agent Name	External Agent
Public IP Address	54.157.67.248

Task Performed

During this engagement, OrbitalFire performed a comprehensive multi-phase network penetration test using standard industry methodologies, including open source intelligence gathering, host discovery, service enumeration, exploitation, and post-exploitation. The specific tasks performed may vary based on the environment and assessment scope.

TASK PERFORMED	DEVICES/LOCATIONS ASSESSED
Collected publicly available information such as domains and IP ranges.	All targets
Identified active systems using ping sweeps, port scans, and ARP sweeps.	All targets
Enumerated open ports and services and identified potential weaknesses.	All active targets identified
Identified and validated vulnerabilities in discovered services.	All active targets identified
Attempted to exploit vulnerabilities to demonstrate potential impact.	Active/Select targets
Gathered evidence of privilege escalation to assess real-world risk.	Active/Select targets

Rules of Engagement

OrbitalFire and OrbitalFire agreed to the following rules of engagements:

ACTIVITY	DEFINITION	PERMISSION
Exploitation	OrbitalFire consultants will cautiously execute exploitation techniques to gain access to sensitive data and/or systems.	Yes
Post Exploitation	If exploitation is successful, OrbitalFire will attempt to escalate privileges within the environment to gain further access to systems and/or data.	Yes

Penetration Test Narrative

This phase of the external network penetration test describes some of the actions performed as part of the penetration test, including host discovery, enumeration, exploitation, and post-exploitation (if opportunities were identified). It should be noted that this portion of the report does not represent the entire list of activities that were performed as part of this assessment, primarily just those that led to some level of access, significant exposure to information, and other activities relevant to the goal of the assessment.

Host Discovery

The first process that was performed during the penetration test was host discovery. Host discovery includes several tasks, including port scanning and ping sweeps, to identify the active systems within the environment. This is a crucial step in the penetration test as it allows attackers to determine what systems are active within the targeted IP addresses and/or ranges.

Of the one (1) IP address/range that was provided as part of the scope, OrbitalFire was able to identify a total of one (1) system to be active within the targeted environment.

MITRE ATT&CK®	
Name	Active Scanning: Scanning IP Blocks
Tactic	Reconnaissance
TTP ID	T1595.001
Note	OrbitalFire also performed a port scan against one (1) target to identify opened ports and running services. Port scanning is also important in that it allows one to identify which ports are opened and visible from the tested system. By discovering opened ports within the environment, it is then possible to determine which services are running and if any of the running services are vulnerable.

Of the one (1) address/range that was scanned, OrbitalFire found three (3) ports opened.

Enumeration

After identifying the available hosts within the network, the next phase is to conduct enumeration. Enumeration consists of scanning the identified ports to determine what services are running. Additional scans are performed based on the running services to attempt enumerating information from the running services (if possible). Such information may be useful for identifying additional vulnerabilities or knowledge for performing an attack against the service.

To help understand the operating systems and ports that were found to be most common within the environment, the following tables display the top 10 operating systems and top 10 ports.

PORT/PROTOCOL	COUNT
443/tcp	1
80/tcp	1
22/tcp	1

OrbitalFire identified one (1) SSH service within the environment and attempted to retrieve banner information, which can be used to identify specific server versions. The following scan results display some of the obtained information:

```
[*] 107.180.245.182 - SSH server version: SSH-2.0-OpenSSH_8.9p1 Ubuntu-3ubuntu0.13
```

Targeting one (1) web application identified running on port 80/tcp, OrbitalFire performed a hidden directory brute force scan to determine if any directories could be identified that may contain sensitive information. During this process, an attacker would usually provide a wordlist containing common names, such as "administrator", "admin", "login", and more. Depending on whether or not one of the web services has a directory containing these common names, the attacker would then attempt to log in or enumerate additional information that may aid other attacks.

After completing the directory enumeration scan on port 80, OrbitalFire was unable to identify any directories that contain information that may be valuable to an attacker.

Targeting one (1) web application identified running on port 443/tcp, OrbitalFire performed a hidden directory brute force scan to determine if any directories could be identified that may contain sensitive information. During this process, an attacker would usually provide a wordlist containing common names, such as "administrator", "admin", "login", and more. Depending on whether or not one of the web services has a directory containing these common names, the attacker would then attempt to log in or enumerate additional information that may aid other attacks.

After completing the directory enumeration scan on port 443, OrbitalFire was unable to identify any directories that contain information that may be valuable to an attacker.

MITRE ATT&CK®	
Name	Brute Force: Password Guessing
Tactic	Credential-access
TTP ID	T1110.001
Note	OrbitalFire also reviewed one (1) SSH server and conducted a limited password attack to determine if any weak or default credentials could be discovered. During this attack, OrbitalFire tried three (3) passwords against several usernames that are commonly configured on SSH servers.

No servers were found to contain weak or default credentials at the time of testing. The following code snippet shows sample output results of this scan:

```
[ATTEMPT] target 107.180.245.182 - login: "ADMIN" - pass: "[obfuscated]" - 29 of 108 [child 8] (0/0)
[ATTEMPT] target 107.180.245.182 - login: "ADMIN" - pass: "[obfuscated]" - 28 of 108 [child 11] (0/0)
[ATTEMPT] target 107.180.245.182 - login: "ADMIN" - pass: "[obfuscated]" - 30 of 108 [child 8] (0/0)
[ATTEMPT] target 107.180.245.182 - login: "Anonymous" - pass: "[obfuscated]" - 41 of 108 [child 4] (0/0)
[ATTEMPT] target 107.180.245.182 - login: "Anonymous" - pass: "[obfuscated]" - 40 of 108 [child 10] (0/0)
[ATTEMPT] target 107.180.245.182 - login: "Anonymous" - pass: "[obfuscated]" - 42 of 108 [child 13] (0/0)
[ATTEMPT] target 107.180.245.182 - login: "Anonymous" - pass: "[obfuscated]" - 40 of 108 [child 14] (0/0)
[ATTEMPT] target 107.180.245.182 - login: "Cisco" - pass: "[obfuscated]" - 11 of 108 [child 10] (0/0)
[ATTEMPT] target 107.180.245.182 - login: "Cisco" - pass: "[obfuscated]" - 10 of 108 [child 9] (0/0)
[ATTEMPT] target 107.180.245.182 - login: "Cisco" - pass: "[obfuscated]" - 12 of 108 [child 11] (0/0)
[ATTEMPT] target 107.180.245.182 - login: "User" - pass: "[obfuscated]" - 17 of 108 [child 4] (0/0)
[ATTEMPT] target 107.180.245.182 - login: "User" - pass: "[obfuscated]" - 16 of 108 [child 15] (0/0)
[ATTEMPT] target 107.180.245.182 - login: "User" - pass: "[obfuscated]" - 18 of 108 [child 1] (0/0)
[ATTEMPT] target 107.180.245.182 - login: "admin" - pass: "[obfuscated]" - 2 of 108 [child 1] (0/0)
[ATTEMPT] target 107.180.245.182 - login: "admin" - pass: "[obfuscated]" - 1 of 108 [child 0] (0/0)
[ATTEMPT] target 107.180.245.182 - login: "admin" - pass: "[obfuscated]" - 3 of 108 [child 2] (0/0)
[ATTEMPT] target 107.180.245.182 - login: "administrator" - pass: "[obfuscated]" - 20 of 108 [child 10] (0/0)
[ATTEMPT] target 107.180.245.182 - login: "administrator" - pass: "[obfuscated]" - 19 of 108 [child 13] (0/0)
[ATTEMPT] target 107.180.245.182 - login: "administrator" - pass: "[obfuscated]" - 21 of 108 [child 7] (0/0)
[ATTEMPT] target 107.180.245.182 - login: "cisco" - pass: "[obfuscated]" - 8 of 108 [child 7] (0/0)

----- SNIPPED -----

The remainder of this output has been snipped for reporting purposes.
```

External Network Environment Exposures

This phase of the security assessment focused on the security of network assets within the external network environment. During this phase, OrbitalFire used a comprehensive set of tools, custom scripts, and manual techniques to thoroughly identify possible threats to the environment. Like a traditional penetration test, all identified threats were tested and validated to evaluate the depth of compromise. Unlike a traditional penetration test, this evaluation of threats was not isolated or limited to a handful of threats, but rather across all threats identified.

**HIGH**

Subdomain Takeover Vulnerability

 Observation

The penetration test identified a potential subdomain takeover vulnerability on one or more domains owned by the organization. This vulnerability typically results from misconfigured DNS records, allowing an attacker to exploit the configuration and gain control over the affected subdomain. The conditions conducive to this exploitation include subdomains pointing to unrecognized or unregistered resource endpoints, which pose a significant risk to the organization's cybersecurity posture.

 Security Impact

If leveraged by an adversary, this subdomain takeover vulnerability could enable unauthorized control of the compromised subdomain. Such control can facilitate the impersonation of the legitimate website, leading to unauthorized data collection, reputation damage, and the potential distribution of harmful content to users. Consequently, both user trust and the organization's credibility may be severely undermined.

 Affected Nodes

ONE (1) AFFECTED URL	
Affected URL	
cyberblastapi.orbitalfire.com	

 Recommendation

To mitigate the identified subdomain takeover vulnerability and bolster the organization's overall security framework, it is essential to implement the following remediation measures:

Remediation Steps

- Remove Misconfigured DNS Records:** Promptly eliminate any DNS records that are misconfigured and vulnerable to takeover, particularly those associated with unregistered or unauthorized services.
- Review DNS Configuration:** Conduct a thorough examination of the DNS configurations to detect and correct any anomalies or misconfigurations. Ensure all DNS records accurately represent the intended services and are adequately secured.

3. **Regularly Monitor DNS Records:** Establish a proactive monitoring strategy that includes regular assessments of DNS records for unauthorized modifications or vulnerabilities. Implement real-time alerting mechanisms to swiftly respond to any suspicious activities.
4. **Implement DNS Security Best Practices:** Adhere to established best practices in DNS security, including the deployment of DNSSEC (Domain Name System Security Extensions) to mitigate DNS spoofing risks and DNS filtering mechanisms to prevent access to malicious domains.



Reproduction Steps

Use a tool like dnsReaper to scan the affected domains and inspect the results for evidence of subdomain takeover vulnerabilities.



References

→ https://developer.mozilla.org/en-US/docs/Web/Security/Subdomain_takeovers



Evidence

cyberblastapi.orbitalfire.com: The defined domain has CNAME records configured for Microsoft Azure but these records do not resolve. An attacker can register this domain on Microsoft Azure and serve their own web content.

MEDIUM

Misconfigured DMARC Record



Observation

The penetration test identified that the organization has a misconfigured DMARC (Domain-based Message Authentication, Reporting, and Conformance) record for its domain(s). DMARC is critical for verifying the authenticity of emails sent from the organization, serving as a vital barrier against email spoofing and phishing attacks. Without proper configuration, DMARC fails to instruct receiving mail servers on how to treat email messages from the organization's domain, thereby increasing vulnerability to attack.



Security Impact

A misconfigured DMARC record poses serious security risks to the organization. If the DMARC policy is set to "none" or is inadequately defined, it creates an opportunity for malicious actors to impersonate the organization's domain. This not only heightens the likelihood of successful phishing attacks but also exposes the organization to potential data breaches, financial losses, and reputational damage as fraudulent emails proliferate.



Affected Nodes

ONE (1) AFFECTED URL

Affected URL

www.orbitalfire.com



Recommendation

To mitigate these risks, it is essential for the organization to promptly review and rectify its DMARC record configuration. The DMARC policy should be explicitly defined, ideally set to "quarantine" or "reject," which directs receiving mail servers on the proper handling of unauthenticated messages. Proper DMARC configuration will significantly bolster the organization's email security posture, diminish the risk of phishing attacks, and safeguard sensitive data. Additionally, effective configuration will facilitate the receipt of reports regarding email authentication failures, enabling the organization to proactively monitor and respond to emerging threats.



Reproduction Steps

There are several publicly available tools to scan for DMARC checks, including:

- dig (command-line tool)
- dnsrecon (command-line tool)
- <https://mxtoolbox.com/dmarc.aspx>



References

→ <https://dmarc.org/>



Evidence

- DMARC record for www.orbitalfire.com has a policy (p=) directive set to "none".

 MEDIUM

Remote SSH Service Exposed to Public Internet

 Observation

Remote administration protocols, including SSH, are critical for network administrators to effectively manage infrastructure components such as routers, switches, and servers. However, when these services are exposed to the public Internet, they become susceptible to a range of cyber threats that can be exploited by malicious actors. This exposure can arise from misconfigurations or default settings that fail to restrict access, leading to increased vulnerabilities that could otherwise be mitigated in a secured environment.

 Security Impact

The public exposure of the SSH service allows attackers to execute password-guessing attempts, enabling unauthorized access to the system. Furthermore, as new vulnerabilities, including zero-day exploits, are discovered and disclosed, attackers can leverage these weaknesses to gain entry. The potential consequences of such unauthorized access can be severe, including the compromise of sensitive information or machine takeover, which may facilitate further attacks within the network, highlighting the critical need for stringent security measures surrounding remote management protocols.

 Affected Nodes

ONE (1) NODE AFFECTED

IP Address	Host Name	Operating System
107.180.245.182		Unknown

 Recommendation

To reduce the risk associated with remote administration protocols, it is strongly advised to completely restrict their accessibility from the public Internet. Implementing a two-factor approach—ensuring that such services are only reachable through secure environments, such as a Virtual Private Network (VPN) or specific authorized IP address configurations—is essential. Regular audits of access controls and continued monitoring for unauthorized access attempts can further enhance security posture.

 Reproduction Steps

Using an SSH client, attempt to establish an SSH connection targeting the affected nodes.

 References

<https://superuser.com/questions/636803/how-risky-it-is-to-have-a-personal-server-with-ssh-opened-to-the-internet>,
<https://security.stackexchange.com/questions/154873/why-is-external-access-to-a-server-via-ssh-considered-insecure>



Evidence

Host: 107.180.245.182 () Ports: 22/open/tcp//ssh//OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)/

Appendix A: Host Discovery (Operating Systems)

External Network Penetration Test

During testing, it was not possible to discover the specific operating systems running on the in-scope targets. This indicates that the targets are configured correctly to not disclose sensitive operating system information, which could be extremely valuable to an attacker looking to exploit vulnerabilities in known operating systems.

Appendix B: Host Discovery (Opened Ports)

External Network Penetration Test

IP Address	DNS Name	Port	Protocol
107.180.245.182		22	tcp
107.180.245.182		80	tcp
107.180.245.182		443	tcp